Ethical Hacking: Stored XSS & Stealing Admin Session Cookies

Kya ek innocent comment box se pure website ka admin account hack ho sakta hai? 💉🔓

1. Unsanitized Comment Post

Agar web application user input ko HTML escape nahi karti toh browser us raw script tag ko render kar deta hai.

```
# RAW PAYLOAD
अगर web application user input को HTML
escape नहीं करती तो browser उस raw script tag
को render कर देता है।
```

2. Stored in Production DB

Admin jab page open karta hai toh script automatically unka authorization token attacker ke server par send kar deti hai.

```
# COOKIE EXFILTRATE
Admin जब page open करता है तो script
automatically उनका authorization token
attacker के server पर send कर देती है।
```